Scénarisation

EXPLICATION INTERMÉDIAIRE

Nom du CTF : Attaque réseau et capture du drapeau (Capture The Flag - CTF)

Objectif du CTF : Le but de ce CTF est de simuler une attaque réseau et d'encourager les participants à découvrir et à exploiter les vulnérabilités de sécurité.

Scénario du CTF : Voici comment se déroule ce CTF :

- **Phase 1 : Communication avec le serveur**
  - L'objectif initial est d'identifier l'adresse du switch sur le réseau.
    Pour cela, trois pistes sont possible :
    - NMAP : via la découverte des périphériques voisins sur la couche 3.
    - Armitage : même fonctionnalité que Nmap.
  - **Tentative d'accès au switch :** L'attaquant tente de se connecter au switch en utilisant l'adresse IP de l'administrateur et en utilisant l'une des trois méthodes suivantes :
    - En exploitant une faille en utilisant un login/mot de passe basique.
    - En tentant de récupérer le login/mdp d'un utilisateur via injection SQL.
  - Suite à la connexion au switch, il faut étudier la configuration du switch pour identifier les points d'attaques.

- **Phase 2 : Identification de la machine cible**
  - On identifie les différents VLAN avec qui le switch interagit.
  - Une fois le VLAN sensible identifié, on cherche une machine disponible.
    Pour l'identifier on utilise les mêmes méthodes que pour l'accès au switch :
    - LLDP : via la découverte de voisin d'un même réseau sur la couche 2.
    - NMAP : via la découverte des périphériques voisins sur la couche 3.
    - Armitage : même fonctionnalité que Nmap.
  - Une fois l'identité de la machine découverte on tente de s'y connecter via le logiciel beEF (qui est un outil d'audit/pentest qui cible les navigateurs web).
  - Quand l'attaquant est connecté à la machine il récupère un token qui lui permettra de se connecter à l'AD

Scénarisation pour l’utilisateur

EXPLICATION MINI
Nom du CTF : Attaque réseau et capture du drapeau (Capture The Flag - CTF)

Objectif du CTF :
Simuler une attaque réseau et exploiter des vulnérabilités de sécurité.

Consignes pour les participants :
Phase 1 : Communication avec le serveur

1. **Objectif initial : Connexion sur le switch**
   1.1. Identifier l'adresse du switch sur le réseau via un outil de découverte réseau
2. **Trois pistes possibles :**
   2.1. **LLDP (Link Layer Discovery Protocol) :** Découvrez les voisins du même réseau sur la couche 2.
   2.2. **NMAP :** Découvrez les périphériques voisins sur la couche 3.
   2.3. **Armitage :** Utilisez la même fonctionnalité que Nmap.
3. **Tentative d'accès au switch :**
   3.1. Tentez de vous connecter au switch en utilisant l'adresse IP de l'administrateur et l'une des méthodes suivantes :
      3.1.1. Tentez de récupérer le login/mot de passe d'un utilisateur via une injection SQL.
      3.1.2. Tentez de récupérer le login/mot de passe d'un utilisateur via le serveur FTP
4. **Suite à la connexion au switch :**
   4.1. Étudiez la configuration du switch pour identifier les points d'attaque.
   4.2. Identifiez les différents VLAN avec lesquels le switch interagit.

Note : Les méthodes ci-dessus peuvent être réalisées en utilisant des outils et protocoles tels que LLDP, NMAP et Armitage.

Phase 2 : Identification de la machine cible

5. **Identifiez un VLAN sensible :**
   5.1. Cherchez une machine disponible dans le VLAN sensible identifié en utilisant les mêmes méthodes que pour l'accès au switch (LLDP, NMAP, Armitage).
6. **Connexion à la machine cible avec beEF :**
   6.1. Utilisez le logiciel beEF (Browser Exploitation Framework), un outil d'audit/pentest ciblant les navigateurs web, pour vous connecter à la machine identifiée.
7. **Récupération du token :**
   7.1. Lorsque l'attaquant est connecté à la machine, récupérez un token qui vous permettra de vous connecter à l'Active Directory (AD).